

Contents

1	Data Security	3
1.1	CIA Triad	3
1.2	Threats	3
2	Access Control	3
2.1	Trojan Horse	4
2.2	Formal Models	4
2.2.1	Mandatory Access Control (MAC)	4
2.2.2	Discretionary Access Control (DAC)	4
2.2.3	Administrative Policies	4
2.2.4	Role-Based Access Control (RBAC)	5
2.2.5	Purpose-Based Access Control (PBAC)	5
2.3	Bell-LaPadula (BLP) Model	8
3	Oracle Database	9
3.1	Oracle Virtual Private Database (VPD)	9
3.2	Oracle Label Security (OLS)	10
3.3	Oracle Vault	10
4	Data Privacy	11
4.1	Offline Privacy	11
4.1.1	k -anonymity	12
4.1.2	m -invariance	13
4.1.3	Differential Privacy	13
4.2	Online Privacy	14
4.2.1	General Data Protection Regulation (GDPR)	14
5	Exercises	15
5.1	BLP Model	15
5.1.1	Resolution	15
5.2	GRANT-REVOKE Model	17
5.2.1	Resolution	17
5.3	RBAC Model	17
5.3.1	Resolution	17
5.4	OLS Model	18
5.4.1	Resolution	18

5.5	HDB Model	20
5.5.1	Resolution	20

1 Data Security

Security deals with protecting data from **unauthorized access, modification, and disruption**. Its main goal is to ensure that **data remain confidential, accurate, and available** to authorized users.

1.1 CIA Triad

The CIA triad is a widely **used model that guides organizations** in their data security practices. It consists of three core principles:

- **Confidentiality:** Ensuring that sensitive information is accessed only by authorized individuals.
- **Integrity:** Maintaining the accuracy and consistency of data over its lifecycle.
- **Availability:** Ensuring that data is accessible to authorized users when needed.

Some **additional security properties** could be considered:

- **Authenticity:** Verifying the **identity of users and systems** to prevent unauthorized access.
- **Accountability:** Ensuring that actions can be traced back to the responsible party, often through **logging and auditing**.
- **Privacy:** Protecting **personal and sensitive information** from unauthorized access and disclosure.

1.2 Threats

A threat is a potential danger to an asset that may lead to a **violation of security**. One important category of threats is **malware**, and the main types of malware are:

- **Virus:** A type of malware that **attaches itself to a legitimate program** or file and spreads to other programs or files when executed.
- **Worm:** A standalone malware that **replicates itself to spread to other computers**, often exploiting vulnerabilities in network protocols.
- **Trojan:** A type of malware that **disguises itself as a legitimate program** or file to trick users into executing it.

2 Access Control

◦ Access control is the traditional center of gravity of computer security. It is where security engineering meets computer science

AC goals Preventing access Limiting access Granting access Revoking access

The very nature of access control suggests that there is an active subject requiring access to a passive object to perform some specific access operations

2.1 Trojan Horse

13/07/2023 – Q4: “Explain what a trojan horse is and how trojan horses can be mitigated through access control.”

...

2.2 Formal Models

Formal models are technical frameworks that define the rules and principles for real-world access control technologies.

2.2.1 Mandatory Access Control (MAC)

...

2.2.2 Discretionary Access Control (DAC)

...

debole ai trojans

2.2.3 Administrative Policies

Authorizations define **who can access what**. Administrative policies define who can create, modify and revoke, **so manage authorizations**.

Types

- **Centralized:** A privileged user (e.g., an administrator) manages all authorizations; Typical of MAC.
- **Owner-based:** The creator of an object manages the authorizations for that object; Native to DAC.
- **Cooperative (multi-party):** Multiple users must approve changes.

Decentralization Trade-off

An owner can even **delegate the administrative privileges** to other users.

This **increases the flexibility** of the administration, but the more decentralized the administration becomes, the **greater the risk** of privilege diffusion.

Design Patterns

A well-designed access control system should follow these **principles and assumptions**:

- **Least Privilege (“need to know”)**: A subject should have only the minimum privileges necessary to perform its task.
- **Maximized Sharing**: Grant a subject all accesses that do not violate integrity and confidentiality of data, as defined the security policies.
- **Closed World Assumption (CWA)**: Access is denied by default. If no authorization is specified for an object, access is prohibited.
- **Open World Assumption (OWA)**: Access is allowed by default. If no authorization is specified for an object, access is granted.

2.2.4 Role-Based Access Control (RBAC)

...

2.2.5 Purpose-Based Access Control (PBAC)

Purpose-Based Access Control (PBAC) is an access control model for relational databases where access decisions depend not only on **who** accesses **what**, but also on **why** the data is accessed. It is a key component of privacy-preserving DBMSs such as Hippocratic DB.

****Purposes****

PBAC addresses three main issues:

- ****Purpose semantics:**** defining what a purpose means.
- ****Data-purpose association:**** associating purposes with data.
- ****Purpose enforcement:**** using purposes during access control decisions.

****Types of Purpose****

- ****Intended Purpose (IP):**** purpose associated with each data item; regulates how the data can be used.
- ****Access Purpose (AP):**** purpose specified when accessing a data item; associated with the query.

IP and AP have different roles:

IP → how the data **can be used** **AP** → how the data **will be used**

****Intended Purpose****

An intended purpose is represented as:

$$IP = \langle AIP, PIP \rangle$$

- ****AIP (Allowed Intended Purposes):**** permitted uses, derived from user preferences.
- ****PIP (Prohibited Intended Purposes):**** forbidden uses, imposed by organizational requirements or privacy laws.
- ****PIP is optional and overrides AIP.****

****Purpose Hierarchy****

Purposes are organized in a hierarchical structure.

For a purpose P :

- $P^\downarrow = \mathbf{P} + \mathbf{descendants\ of\ P}$
- $P^\uparrow = \mathbf{P} + \mathbf{ancestors\ of\ P}$
- $P^\updownarrow = P^\downarrow \cup P^\uparrow$

The effective set of allowed purposes is:

$$IP^* = AIP^\downarrow - PIP^\updownarrow$$

Therefore, a purpose is allowed only if it belongs to the effective set IP^* .

****Purpose-Based Authorization****

Users are granted purpose-based authorizations, which can be based on:

- users
- roles
- attributes

An authorization can be represented as:

$$\langle ap, obj, r/u \rangle$$

where ap is the access purpose, obj the protected object and r/u the allowed operation.

****PBAC Enforcement****

Users must explicitly specify the **AP** when issuing a query:

```
1 SELECT email FROM Customer FOR Marketing
```

A user u can execute query q with access purpose AP iff:

1. The **authorization base contains a supporting authorization**.
2. The **IPs associated with the accessed data are compliant with AP**.

Purpose compliance:

$$AP \in IP^*$$

equivalently:

$$AP \in AIP^\downarrow \quad \wedge \quad AP \notin PIP^\uparrow$$

****Enforcement Techniques****

- ****Query Rewriting:**** the query q is rewritten into q' so that it only accesses data whose IPs are compliant with the AP.
- ****Post-processing:**** the DBMS filters from the result of q the tuples whose IPs are not compliant with the AP.

****Why PBAC?****

- Enforces the **purpose limitation principle**.
- Reduces the risk of **secondary data usage**.
- Provides a formal enforcement model for purpose-based privacy policies.

****Limitations****

- Purpose definitions can be **ambiguous**.
- Authorization management can be **complex**.
- Query rewriting introduces **overhead**.

2.3 Bell-LaPadula (BLP) Model

Bell-LaPadula (BLP) model is a MAC-based framework designed for maintaining the confidentiality of information by **restricting access based on security levels**.

Security Levels

Security levels are organized in a hierarchical structure, with higher levels representing more sensitive information, such as:

$$TS > S > C > U$$

That is: **Top Secret (TS)** is the highest level, followed by **Secret (S)**, **Confidential (C)**, and **Unclassified (U)**.

Categories

Categories are used to further **refine the classification of information** within each security level.

Assume to have a subject with a security level of S and categories $\{Alpha, Beta\}$:

$$S : \{Alpha, Beta\}$$

READ

To read an object, **the subject should dominate the object**. This means that:

$$L_s \geq L_o \quad \text{and} \quad C_o \subseteq C_s$$

The **Simple Security Property (ss-property, “no read up”)** states that information can only flow **upwards** in the hierarchy, meaning that a subject can read an object only if the subject’s security level is greater than or equal to the object’s level, and the object’s categories are a subset of the subject’s categories.

WRITE

To write to an object, **the object should dominate the subject**. This means that:

$$L_o \geq L_s \quad \text{and} \quad C_s \subseteq C_o$$

The **Star Property (*-property, “no write down”)** states that information can only flow **downwards** in the hierarchy, meaning that a subject can write to an object only if the object’s security level is greater than or equal to the subject’s level, and the subject’s categories are a subset of the object’s categories.

3 Oracle Database

Oracle Database is a **relational database management system (RDBMS)** developed by Oracle Corporation.

3.1 Oracle Virtual Private Database (VPD)

Oracle Virtual Private Database (VPD) is a security mechanism that allows to restrict access to database objects to be restricted **at the row level**.

VPD associates **access control policies** with database objects. When a user issues a query, the policy can dynamically determine which rows the user is allowed to access based on **user or session attributes**.

Features

The main features of VPD are:

- **Fine-Grained Access Control (FGAC):** Access to data can be restricted **at row level**, rather than only at the level of entire tables or objects.
- **Attribute-Based Access Control (ABAC):** Access decisions can depend on **user/session attributes**, such as the user identity or the time at which the request is issued.
- **Dynamic policies:** The access condition can be **dynamically determined** according to the characteristics of the requesting user or session. The **policy function** can be implemented as a PL/SQL function, which is then attached to the protected table.
- **Transparent enforcement:** The policy is applied to queries **accessing the protected object**, so users see only the rows they are authorized to access.

The combination of FGAC and ABAC allows VPD to define and enforce **row-level access control policies based on attributes**.

3.2 Oracle Label Security (OLS)

OLS will be well explained in the **Exercises** chapter.

3.3 Oracle Vault

Oracle Database Vault is a security mechanism designed to protect sensitive data **even from highly privileged database users**.

Purposes

The main purposes of this database mechanism are:

- **Restrict access of highly privileged users** to sensitive database objects.
- **Enforce Separation of Duty**, so that different administrative responsibilities can be separated.
- Provide some **support for ABAC and FGAC** to some extent.
- Support **security and compliance requirements**, e.g. GDPR.

A key motivation is that mechanisms such as VPD mainly protect ordinary users, whereas a DBA **may be able to bypass VPD policies**.

Features

The main features of this system are:

- **Realm:** A **protected zone of the database** containing selected database objects and roles. Access to the objects inside the realm is **controlled separately**, so even a user with powerful database privileges cannot automatically access them.
- **Authorization:** The process of **granting or denying access** to a realm based on the user's identity, role, or other attributes.
- **Ruleset:** A set of rules that **define the conditions under which access** to a realm is granted or denied. Rulesets can be **based on various factors**, such as user identity, time of day, or IP address.

The combination of these features **supports ABAC and FGAC**.

Commands

The main commands for managing Oracle Database Vault are:

- **CREATE_REALM:** Creates a new realm in the database.
- **ADD_OBJECT_TO_REALM:** Adds a database object (e.g., table, view, procedure) to a specified realm.
- **ADD_AUTH_TO_REALM:** Adds a user or role to a specified realm. Optional, you can also specify a ruleset to define the conditions for access.
- **CREATE_RULE:** Creates a new rule that defines the conditions for access to a realm.
- **CREATE_RULE_SET:** Creates a new ruleset that can contain multiple rules.
- **ADD_RULE_TO_RULE_SET:** Adds a rule to a specified ruleset.

These commands **build the foundation** for implementing Oracle Database Vault.

4 Data Privacy

Privacy is the right of individuals to **control their personal information**, including how it is **collected, stored, and shared**, while protecting their **Personal Identifiable Information (PII)**.

4.1 Offline Privacy

Offline privacy concerns the protection of individuals' privacy when **microdata are shared** with a third party. Mainly, there are **two approaches** to protect privacy:

- **Non-interactive:** Release a *sanitized version* of the data.
- **Interactive:** Provide a *query interface* to the data, allowing users to access information without exposing the raw data.

Attribute Classification

Attributes in a dataset can be classified into **three categories**:

- **Identifiers:** Directly identify an individual.
- **Quasi-Identifiers (QI):** Attributes that can identify individuals when combined with external information.
- **Sensitive attributes:** Private information that the data publisher wants to protect.

An example of a dataset with these attribute classifications **is shown below**:

Identifier	Quasi-Identifier	Sensitive Attribute
NameSurname	BirthDate	Disease
-	-	-
John Doe	01-01-1980	Cancer
Jane Smith	02-02-1990	Diabetes

4.1.1 *k*-anonymity

A released table **satisfies *k*-anonymity** if every combination of QI values occurring in the released table occurs in at least k records.

1. Therefore, each record **is indistinguishable** from at least $\geq k - 1$ other records with respect to the quasi-identifiers.
2. These k records form an **equivalence class**.
3. Links attacks cannot be performed with a confidence **greater than** $\frac{1}{k}$.

To achieve *k*-anonymity is necessary to apply **two techniques**:

- **Generalization:** Replace specific QI values with **less specific values** until at least k records have identical QI values.
- **Suppression:** Remove records when generalization would cause **excessive information loss**.

Limitations

k -anonymity does not guarantee protection against **attribute disclosure**:

- **Homogeneity attack**: All records in an equivalence class have the same sensitive attribute value.
- **Background knowledge attack**: An attacker can use external information to infer sensitive attribute values.

That is the reason why k -anonymity was extended to l -diversity, which requires that each equivalence class has at least l distinct values for the sensitive attribute.

This approach addresses the problem of homogeneous sensitive values, but can still suffer from **skewness attacks** and **similarity attacks**.

4.1.2 m -invariance

A sequence of generalized tables $T(1), \dots, T(n)$ is **m -invariant** if and only if:

- Every table $T(1), \dots, T(n)$ is **m -unique**.
- Each individual **has the same signature** in every generalized table in which they appear.

A generalized table $T(j)$ is **m -unique** if and only if:

- Each QI-group in $T(j)$ contains at least m **tuples**.
- All tuples within the same QI-group have **distinct sensitive values**.

4.1.3 Differential Privacy

Differential privacy protects against the additional **risk caused by the participation** in the database.

Let D and D' be two datasets differing from at most one tuple. Let Q be a query answering algo, and let $Q(D)$ be the result returned by Q when executed on dataset D . Q satisfies ϵ – differential privacy if for any possible output o :

$$\frac{\Pr[Q(D) = o]}{\Pr[Q(D') = o]} \leq e^\epsilon \sim (1 + \epsilon)$$

To achieve differential privacy, **some techniques** can be applied:

- Output perturbation
- Input perturbation

- Perturbation of intermediate values
- Perturbation during training

Types

Two main types of differential privacy are:

- **Local:** Provides **stronger privacy** guarantees, as the data is perturbed before being sent to the server.
- **Central:** Provides **higher utility**, as the server can apply more sophisticated techniques to the raw data before perturbation.

4.2 Online Privacy

Online privacy concerns the protection of personal data **throughout the information life cycle**, from collection to storage, use, and destruction. The main framework for online privacy in the EU is the **GDPR (General Data Protection Regulation)**.

4.2.1 General Data Protection Regulation (GDPR)

The GDPR regulates the different stages of the **information life cycle**:

1. **Capture:** What data can be collected, how they can be collected, and what the individual **must be informed about**.
2. **Store:** How and where **data can be stored** and how they **must be protected**.
3. **Use:** Data can only be used for **permitted and specified purposes**.
4. **Destroy:** Data should be kept only for the **necessary period** and then **deleted**.

Pillars

The main pillars and techniques are:

- **Purpose limitation:** Data should only be used for **specified and legitimate purposes**.
- **Data minimisation:** Only the **necessary data** should be collected and processed.
- **Accuracy:** Personal data should be **accurate and kept up to date**.
- **Storage limitation:** Personal data should be retained for **no longer than necessary**.
- **Lawfulness, fairness and transparency:** Personal data must be processed **lawfully, fairly, and transparently**.

- **Integrity and confidentiality:** Personal data must be protected against *unauthorized access, loss, or disclosure*.
- **Accountability:** Organizations must be able to *demonstrate compliance* with GDPR requirements.

5 Exercises

5.1 BLP Model

Let us consider BLP and the following security levels:

- **Security levels:** $TS > S > C > U$

Let us consider a subject s with session label:

- $S : \{Chemical, Financial, Research\}$

Which operations can s perform on a data object o with the following labels?

1. $TS : \{\}$
2. $S : \{Financial, Chemical\}$
3. $U : \{Financial, Marketing\}$
4. $C : \{Chemical, Financial, Research\}$
5. $TS : \{Chemical\}$

5.1.1 Resolution

1. $TS : \{\}$

- **READ:**

1. $S \geq TS \rightarrow \text{False}$

- **WRITE:**

1. $TS \geq S \rightarrow \text{True}$
2. $\{Chemical, Financial, Research\} \subseteq \{\} \rightarrow \text{False}$

- **Result:** User cannot perform **READ** and cannot perform **WRITE**. Neither the subject nor the object dominate the other, so they are incomparable.

2. $S : \{Financial, Chemical\}$

- **READ:**

1. $S \geq S \rightarrow \text{True}$

2. $\{\text{Chemical}, \text{Financial}\} \subseteq \{\text{Financial}, \text{Chemical}, \text{Research}\} \rightarrow \text{True}$

- **WRITE:**

1. $S \leq S \rightarrow \text{True}$

2. $\{\text{Chemical}, \text{Financial}, \text{Research}\} \subseteq \{\text{Financial}, \text{Chemical}\} \rightarrow \text{False}$

- **Result:** User can perform **READ** but cannot perform **WRITE**. The subject dominates the object, but not vice versa.

3. $U : \{\text{Financial}, \text{Marketing}\}$

- **READ:**

1. $S \geq U \rightarrow \text{True}$

2. $\{\text{Financial}, \text{Marketing}\} \subseteq \{\text{Chemical}, \text{Financial}, \text{Research}\} \rightarrow \text{False}$

- **WRITE:**

1. $U \geq S \rightarrow \text{False}$

- **Result:** User cannot perform **READ** and cannot perform **WRITE**. Neither the subject nor the object dominate the other, so they are incomparable.

4. $C : \{\text{Chemical}, \text{Financial}, \text{Research}\}$

- **READ:**

1. $S \geq C \rightarrow \text{True}$

2. $\{\text{Chemical}, \text{Financial}, \text{Research}\} \subseteq \{\text{Chemical}, \text{Financial}, \text{Research}\} \rightarrow \text{True}$

- **WRITE:**

1. $C \geq S \rightarrow \text{False}$

- **Result:** User can perform **READ** but cannot perform **WRITE**. The subject dominates the object, but not vice versa.

5. $TS : \{\text{Chemical}\}$

- **READ:**

1. $S \geq TS \rightarrow \text{False}$

- **WRITE:**

1. $TS \geq S \rightarrow \text{True}$

2. $\{\text{Chemical}, \text{Financial}, \text{Research}\} \subseteq \{\text{Chemical}\} \rightarrow \text{False}$

- **Result:** User cannot perform **READ** and cannot perform **WRITE**. Neither the subject nor the object dominate the other, so they are incomparable.

5.2 GRANT-REVOKE Model

Let us consider the System R access control model and suppose that user Alice creates table $T(A,B,C,D)$ at time 5. Consider the following grant operations: 1. At time 7 Alice grants Mark and Mary the select and insert privileges on T with grant option. 2. At time 8 Alice grants Ann the select privilege on T with grant option. 3. At time 9 Mary grants Tim the select privilege on T with grant option. 4. At time 12 Ann grants Mary the select privilege on T with grant option. 5. At time 14 Mark grants Mary the insert privilege on T with grant option. 6. At time 20 Alice revokes Mark and Mary the privileges previously granted. Answer the following questions: 1. Which is the effect of the command at point 6) on the authorization base by considering: a. The System R authorization model? b. SQL? 2. Suppose that Alice wants to grant Mathias the privilege to access those tuples of table T such that $A > 10$. How can this requirement be implemented: a. In the System R access control model? b. In the SQL standard? c. In the Oracle DBMS?

5.2.1 Resolution

...

5.3 RBAC Model

Suppose to have a company with 4 roles $R1, R2, R3, R4$, and a table T . Suppose that $R1, R2$ and $R4$ should be granted the **SELECT** privilege on T , $R3$ and $R4$ should be granted the **UPDATE** privilege on T , whereas only $R4$ should have the **DELETE** privilege on T .

Implement the abovementioned access control requirements with the RBAC support provided by SQL, by specifying the minimum number of authorizations.

5.3.1 Resolution

1. Create the roles:

```
1 CREATE ROLE R1;  
2 CREATE ROLE R2;  
3 CREATE ROLE R3;  
4 CREATE ROLE R4;
```

2. Assign the privileges:

```
1 GRANT SELECT ON T TO R1; -- SELECT → R1  
2 GRANT R1 TO R2;         -- SELECT → R2
```

```

3 GRANT UPDATE ON T TO R3; -- UPDATE → R3
4 GRANT R1 TO R4;          -- SELECT → R4
5 GRANT R3 TO R4;          -- UPDATE → R4
6 GRANT DELETE ON T TO R4; -- DELETE → R4

```

3. The minimum number of authorizations **is 6**.

5.4 OLS Model

Let us consider OLS and the following security levels:

- **Security levels:** $TS > S > C > U$
- **Compartments:** Alpha, Beta, Gamma
- **Groups:** France, NATO, Italy

Let us consider a subject s with session label:

- $S : \{Alpha, Beta\} : \{NATO\}$

And suppose the following authorizations for s are derived from his/her user label:

- **Alpha:** rw
- **Beta:** r
- **Gamma:** r
- **NATO:** rw
- **Minimum Level for Write operations (MLW):** C

Which operations can s perform on a data object o with the following labels?

1. $S : \{Beta\} : \{France, NATO\}$
2. $C : \{Alpha, Beta\} : \{NATO\}$
3. $C : \{Alpha, Beta\} : \{\}$
4. $U : \{Alpha\}$
5. $C : \{\} : \{Italy\}$

5.4.1 Resolution

1. $S : \{Beta\} : \{France, NATO\}$
 - **READ:**
 1. $S \geq C \rightarrow \text{True}$

2. $\{Beta\} \subseteq \{Alpha, Beta\} \rightarrow \text{True}$
3. $\{NATO\} \cap \{France, NATO\} \neq \emptyset \rightarrow \text{True}$

• **WRITE:**

1. $(L_s \geq MLW) \rightarrow (S \geq C) \rightarrow \text{True}$
2. $(\{w\} \cap A_{France} \neq \emptyset) \vee (\{w\} \cap A_{NATO} \neq \emptyset) \rightarrow \text{True}$
3. $\{w\} \cap A_{Beta} \neq \emptyset \rightarrow \text{False}$

• **Result:** User can perform **READ** but cannot perform **WRITE**.

2. $C : \{Alpha, Beta\} : \{NATO\}$

• **READ:**

1. $S \geq C \rightarrow \text{True}$
2. $\{Alpha, Beta\} \subseteq \{Alpha, Beta\} \rightarrow \text{True}$
3. $\{NATO\} \cap \{NATO\} \neq \emptyset \rightarrow \text{True}$

• **WRITE:**

1. $(L_s \geq MLW) \rightarrow (C \geq C) \rightarrow \text{True}$
2. $\{w\} \cap A_{NATO} \neq \emptyset \rightarrow \text{True}$
3. $(\{w\} \cap A_{Alpha} \neq \emptyset) \wedge (\{w\} \cap A_{Beta} \neq \emptyset) \rightarrow \text{False}$

• **Result:** User can perform **READ** but cannot perform **WRITE**.

3. $C : \{Alpha, Beta\} : \{\}$

• **READ:**

1. $S \geq C \rightarrow \text{True}$
2. $\{Alpha, Beta\} \subseteq \{Alpha, Beta\} \rightarrow \text{True}$

• **WRITE:**

1. $(L_s \geq MLW) \rightarrow (C \geq C) \rightarrow \text{True}$
2. $(\{w\} \cap A_{Alpha} \neq \emptyset) \wedge (\{w\} \cap A_{Beta} \neq \emptyset) \rightarrow \text{False}$

• **Result:** User can perform **READ** but cannot perform **WRITE**.

4. $U : \{Alpha\} : \{\}$

• **READ:**

1. $S \geq U \rightarrow \text{True}$
2. $\{Alpha\} \subseteq \{Alpha, Beta\} \rightarrow \text{True}$

• **WRITE:**

1. $(L_s \geq MLW) \rightarrow (U \geq C) \rightarrow \text{False}$

• **Result:** User can perform **READ** but cannot perform **WRITE**.

5. $C : \{\} : \{Italy\}$

- **READ:**

1. $C \geq C \rightarrow \text{True}$
2. $\{\} \subseteq \{Alpha, Beta\} \rightarrow \text{False}$

- **Result:** User cannot perform **READ** and cannot perform **WRITE**.

5.5 HDB Model

Exercise 3 Consider the Hippocratic DB access control model and table $T(A,B,C,D)$. Consider two customers Pamela and Patt whose personal data are stored into table T , with the following privacy preferences: • Pamela: A, B, and C can be read for purpose P1, while A and B can be read also for purpose P2. • Patt: A, B, and D can be read for purpose P1. Suppose that there are two employees Panos and Athena working in the company where table T is hosted and that they must be granted the following authorizations:

- Panos can read A and B for purpose P1, while Athena can access all the info in T for purposes P1 and P2. Finally suppose that the privacy policy of the company states that it keeps information on table T for purposes P1 and P2. The retention period is 1 month for P1 and 3 months for P2. Columns A and C of table T are shared with third party KGK for purpose P1. 1. It is required to model the above-mentioned privacy requirements using the Hippocratic database metadata. 2. Consider query $q = \text{SELECT } A, B \text{ FROM } T$. Explain which checks the DB performs and which is the results when: a. The purpose associated with the query is P2, and the user submitting the query is Panos. b. The purpose associated with the query is P2, and the user submitting the query is Athena. c. The purpose associated with the query is P1, and the user submitting the query is Panos.

5.5.1 Resolution

...